

第1章 网络安全概论

1. 选择题

(1) 计算机网络安全是指利用计算机网络管理控制和技术措施, 保证在网络环境中数据的 _____、完整性、网络服务可用性和可审查性受到保护。

- A. 机密性 B. 抗攻击性
- C. 网络服务管理性 D. 控制安全性

(2) 网络安全的实质和关键是保护网络的 _____ 安全。

- A. 系统 B. 软件
- C. 信息 D. 网站

(3) 下面不属于 TCSEC 标准定义的系统安全等级的 4 个方面是。

- A. 安全政策 B. 可说明性
- C. 安全保障 D. 安全特征

(4) 在短时间内向网络中的某台服务器发送大量无效连接请求, 导致合法用户暂时无法访问服务器的攻击行为是破坏了 _____。

- A. 机密性 B. 完整性
- C. 可用性 D. 可控性

(5) 如果访问者有意避开系统的访问控制机制, 则该访问者对网络设备及资源进行非正常使用属于 _____。

- A. 破坏数据完整性 B. 非授权访问
- C. 信息泄漏 D. 拒绝服务攻击

答案: (1) A (2) C (3) D (4) C (5) B

2. 填空题

(1) 计算机网络安全是一门涉及 _____、_____、_____、通信技术、应用数学、密码技术、信息论等多学科的综合性学科。

答案: 计算机科学、网络技术、信息安全技术

(2) 网络安全的 5 大要素和技术特征, 分别是 _____、_____、_____、_____、_____。

答案: 机密性、完整性、可用性、可控性、不可否认性

(3) 计算机网络安全所涉及的内容包括是 _____、_____、_____、_____、_____等五个方面。

答案: 实体安全、运行安全、系统安全、应用安全、管理安全

(4) 网络信息安全保障包括 _____、_____、_____和 _____ 四个方面。

(5) 网络安全关键技术分为 _____、_____、_____、_____、_____、_____和 _____ 八大类。

(6) 网络安全技术的发展具有 _____、_____、_____、_____ 的特点。

(7) TCSEC 是可信计算机系统评价准则的缩写，又称网络安全橙皮书，将安全分为_____、_____、_____和文档四个方面。

(8)通过对计算机网络系统进行全面、充分、有效的安全评测，能够快速查出_____、_____、_____。

答案:

- (4) 信息安全策略、信息安全管理、信息安全运作和信息安全技术
- (5) 身份认证、访问管理、加密、防恶意代码、加固、监控、审核跟踪和备份恢复
- (6) 多维主动、综合性、智能化、全方位防御
- (7) 安全政策、可说明性、安全保障
- (8) 网络安全隐患、安全漏洞、网络系统的抗攻击能力

3. 简答题

(1) 简述网络安全关键技术的内容？

网络安全关键技术主要包括：

- (1) 身份认证（Identity and Authentication Management）
- (2) 访问管理（Access Management）
- (3) 加密（Cryptograghy）
- (4) 防恶意代码（Anti-Malicode）
- (5) 加固（Hardening）
- (6) 监控（Monitoring）
- (7) 审核跟踪（Audit Trail）
- (8) 备份恢复（Backup and Recovery）

(3) 网络安全框架由哪几部分组成？

- (1)信息安全战略
- (2)信息安全政策和标准
- (3)信息安全管理
- (4)信息安全运作
- (5)信息安全技术

(6) 网络安全设计的原则有哪些？

在进行网络系统安全方案设计、规划时，应遵循以下 7 项基本原则：

- (1) 综合性、整体性原则
- (2) 需求、风险、代价平衡的原则
- (3)一致性原则
- (4)易操作性原则
- (5) 分步实施原则
- (6) 多重保护原则
- (7) 可评价性原则

(7) 网络安全的设计步骤是什么？

根据信息安全标准和网络安全设计的原则,可以确定网络安全设计的 5 个步骤:

- (1) 明确安全需求, 进行风险分析
- (2) 选择并确定网络安全措施
- (3) 方案实施
- (4) 网络试验及运行
- (5) 优化及改进

第 2 章 网络安全技术基础

1. 选择题

- (1) SSL 协议是 () 之间实现加密传输的协议。
A.物理层和网络层
B.网络层和系统层
C.传输层和应用层
D.物理层和数据层
- (2) 加密安全机制提供了数据的 ()。
A.可靠性和安全性
B.保密性和可控性
C.完整性和安全性
D.保密性和完整性
- (3) 抗抵赖性服务对证明信息的管理与具体服务项目和公证机制密切相关, 通常都建立在 () 层之上。
A.物理层
B.网络层
C.传输层
D.应用层
- (4) 能在物理层、链路层、网络层、传输层和应用层提供的网络安全服务的是 ()。
A.认证服务
B.数据保密性服务
C.数据完整性服务
D.访问控制服务
- (5) 传输层由于可以提供真正的端到端的连接, 最适宜提供 () 安全服务。
A.数据保密性
B.数据完整性
C.访问控制服务
D.认证服务

解答: (1) C (2) D (3) D (4) B (5) B

2. 填空题

(1) 应用层安全分解成_____、_____、_____ 的安全, 利用_____ 各种协议运行和管理。

解答: (1) 网络层、操作系统、数据库、TCP/IP

(2) 安全套层 SSL 协议是在网络传输过程中, 提供通信双方网络信息的_____ 性和_____ 性, 由_____ 和_____ 两层组成。

解答: (2) 保密性、可靠性、SSL 记录协议、SSL 握手协议

(3) OSI/RM 开放式系统互连参考模型七层协议是_____、_____、_____、_____、_____、_____、_____。

_____、_____、_____。

解答:物理层、数据链路层、网络层、传输层、会话层、表示层、应用层

(4) ISO 对 OSI 规定了_____、_____、_____、_____、_____五种级别的安全服务。

解答: 对象认证、访问控制、数据保密性、数据完整性、防抵赖

(5) 一个 VPN 连接由 _____、_____和_____ 三部分组成。一个高效、成功的 VPN 具有 _____、_____、_____、_____ 四个特点。

解答: 客户机、隧道、服务器、安全保障、服务质量保证、可扩充和灵活性、可管理性

3.简答题

(2) 简述 IPV6 协议的基本特征及与 IPV4 的 IP 报头格式的区别？

TCP/IP的所有协议的数据都以IP数据报的形式传输，TCP/IP协议簇有两种IP版本：IPv4和IPv6。

IPv4的IP地址是TCP/IP网络中唯一指定主机的32位地址,一个IP包头占20字节包括IP版本号、长度、服务类型和其他配置信息及控制字段。IPv4在设计之初没有考虑安全性，IP包本身并不具有任何安全特性。

IPv6 简化了 IP 头，其数据报更加灵活，同时 IPv6 还增加了对安全性的设计。 IPv6 协议相对于 IPv4 协议有许多重要的改进，具有以下**基本特征**：

(1)扩展地址空间：IPv6 将 IPv4 的 IP 地址从 32 位扩充到 128 位，这使得网络的规模可以得到充分扩展，连接所有可能的装置和设备，并使用唯一的全局网络地址。

(2)简化报头：IPv4 有许多域和选项，由于报头长度不固定，不利于高效地处理，也不便于扩展。IP v6 针对这种实际情况，对报头进行了重新设计，由一个简化的长度固定的基本报头和多个可选的扩展报头组成。这样既加快了路由速度，又能灵活地支持多种应用，还便于以后扩展新的应用。IPv4 及 IPV6 基本报头如图 2-8 和图 2-9 所示。

版本（4位）	头长度（4位）	服务类型（8位）	封包总长度（16位）
封包标识（16位）		标志（3位）	片断偏移地址（13位）
存活时间（8位）	协议（8位）	校验和（16位）	
来源IP地址（32位）			
目的IP地址（32位）			
选项（可选）		填充（可选）	
数据			

图 2-8 IPV4 的 IP 报头

版本号	业务流类别	流标签	
净荷长度		下一头	跳数限制
源地址			
目的地址			

图 2-9 IPV6 基本报头

(3)更好支持服务质量 QoS (Quality of Service):为上层特殊应用的传送信息流可以用流标签来识别，便于专门的处理。

(4)改善路由性能：层次化的地址分配便于实现路由聚合，进而减少路由表的表项，而简化的 IP 分组头部也减少了路由器的处理负载。

(5)内嵌的安全机制：要求强制实现 IPSec，提供了支持数据源发认证、完整性和保密性的能力，同时可以抗重放攻击。IPv6 内嵌的安全机制主要由以下两个扩展报头来实现：**认证头 AH(Authentication Header)**和**封装安全载荷 ESP(Encapsulation Security Payload)**。

◆ 其中认证头 AH 可以实现以下三个功能：保护数据完整性(即不被非法篡改)；数据源发认证(即防止源地址假冒)和抗重放(Replay)攻击。

◆ 封装安全载荷 ESP 则在 AH 所实现的安全功能基础上，还增加了对数据保密性的支持。

◆ AH 和 ESP 都有两种使用方式：传输模式和隧道模式。传输模式只应用于主机实现，并只提供对上层协议的保护，而不保护 IP 报头。隧道模式（一种以隐含形式把数据包封装到隧道协议中传输数据的方法，将在 2.4.2 介绍）可用于主机或安全网关。在隧道模式中，内部的 IP 报头带有最终的源和目的地址，而外面的 IP 报头可能包含性质不同的 IP 地址，如安全网关地址。

(6) 简述无线网络的安全问题及保证安全的基本技术？

1. 无线网络的安全问题

无线网络的数据传输是利用微波进行辐射传播，因此，只要在 Access Point (AP)覆盖的范围内，所有的无线终端都可以接收到无线信号，AP 无法将无线信号定向到一个特定的接收设备，因此，无线的安全保密问题就显得尤为突出。

2. 无线安全基本技术

(1) 访问控制-利用 ESSID、MAC 限制，可以防止非法无线设备入侵

(2) 数据加密-基于 WEP 的安全解决方案

(3) 新一代无线安全技术——IEEE802.11i

(4) TKIP-新一代的加密技术 TKIP 与 WEP 一样基于 RC4 加密算法

(5) AES- 是一种对称的块加密技术，提供比 WEP/TKIP 中 RC4 算法更高的加密性能

(6) 端口访问控制技术（IEEE802.1x）和可扩展认证协议（EAP）

(7) WPA（WiFi Protected Access）规范- WPA 是一种可替代 WEP 的无线安全技术

第 3 章 网络安全管理技术

1. 选择题

(1) 计算机网络安全管理主要功能不包括（ ）。

A.性能和配置管理功能

B.安全和计费管理功能

C.故障管理功能

D.网络规划和网络管理者的管理功能

(2) 网络安全管理技术涉及网络安全技术和管理的很多方面，从广义的范围来看（ ）是安全网络管理的一种手段。

A.扫描和评估

B. 防火墙和入侵检测系统安全设备

C.监控和审计

D. 防火墙及杀毒软件

(3) 名字服务、事务服务、时间服务和安全性服务是（ ）提供的服务。

A. 远程 IT 管理的整合式应用管理技术 B. APM 网络安全管理技术

C. CORBA 网络安全管理技术

D. 基于 WeB 的网络管理模式

(4) 与安全有关的事件, 如企业猜测密码、使用未经授权的权限访问、修改应用软件以及系统软件等属于安全实施的 ()。

A. 信息和软件的安全存储

B. 安装入侵检测系统并监视

C. 对网络系统及时安装最新补丁软件

D. 启动系统事件日志

(5) () 功能是使用户能够能过轮询、设置关键字和监视网络事件来达到网络管理目的, 并且已经发展成为各种网络及网络设备的网络管理协议标准。

A. TCP/IP 协议

B. 公共管理信息协议 CMIS/CMIP

C. 简单网络管理协议 SNMP

D. 用户数据报文协议 UDP

解答: (1) D (2) B (3) C (4) D (5) C

2. 填空题

(1) OSI/RM 安全管理包括____、____和____, 其处理的管理信息存储在____或____中。

解答: (1) 系统安全管理、安全服务管理、安全机制管理、数据表、文件

(2) 网络安全管理功能包括计算机网络的____、____、____、____等所需要的各种活动。ISO 定义的开放系统的计算机网络管理的功能包括____、____、____、____。

(2) 运行、处理、维护、服务提供、故障管理功能、配置管理功能、性能管理功能、安全管理功能、计费管理功能

(3) _____是信息安全保障体系的一个重要组成部分, 按照_____的思想, 为实现信息安全战略而搭建。一般来说防护体系包括____、____和____三层防护结构。

(3) 信息安全管理体系、多层防护、认知宣传教育、组织管理控制、审计监督

(4) 网络管理是通过_____来实现的, 基本模型由____、____和____三部分构成。

(4) 构建网络管理系统 NMS、网络管理工作站、代理、管理数据库

(5) 在网络管理系统的组成部分中, _____最重要, 最有影响的是_____和_____代表了两大网络管理解决方案。

(5) 网络管理协议、SNMP、CMIS/CMIP

3. 简答题

1. 网络安全管理技术概念

网络安全管理技术一般需要实施一个基于多层次安全防护的策略和管理协议，将网络访问控制、入侵检测、病毒检测和网络流量管理等安全技术应用于内网，进行统一的管理和控制，各种安全技术彼此补充、相互配合，对网络行为进行检测和控制，形成一个安全策略集中管理、安全检查机制分散布置的分布式安全防护体系结构，实现对内网进行安全保护和管理。

(4) 网络管理系统的逻辑模型的构成及各组成部分的内容是什么?

- 多个被管代理 (Managed Agents) 及被管理对象 (Managed Object)
- 用于执行具体管理工作的网络管理器 (Network Management)
- 公共网络管理协议 (Network Manager Protocol, 简 NMP)
- 系统管理应用进程 (System Management Application Programme, 简称管理进程 SMAP)
- 管理信息库 (Management Information Base, 简称 MIB)。

1. 选择题

- (1) 在黑客攻击技术中, () 黑客发现获得主机信息的一种最佳途径。
A. 网络监听
B. 缓冲区溢出
C. 端口扫描
D. 口令破解
- (2) 一般情况下, 大多数监听工具不能够分析的协议是 ()。
A. 标准以太网
B. TCP/IP
C. SNMP 和 CMIS
D. IPX 和 DECNet
- (3) 改变路由信息、修改 WinDows NT 注册表等行为属于拒绝服务攻击的 () 方式。
A. 资源消耗型
B. 配置修改型

C.服务利用型

D. 物理破坏型

(4) () 是建立完善的访问控制策略, 及时发现网络遭受攻击情况并加以追踪和防范, 避免对网络造成更大损失。

A. 动态站点监控

B.实施存取控制

C. 安全管理检测

D.完善服务器系统安全性能

(5) () 是一种新出现的远程监控工具, 可以远程上传、修改注册表等, 集聚危险性还在于, 在服务端被执行后, 如果发现防火墙就会终止该进程, 使安装的防火墙完全失去控制。

A.冰河

B.网络公牛

C.网络神偷

D.广外女生

解答: (1) C (2) C (3) B (4) A (5) D

2. 填空题

(1) 黑客的“攻击五部曲”是_____、_____、_____、_____、_____。

解答: 隐藏 IP、 踩点扫描、获得特权、种植后门、隐身退出

(2) 端口扫描的防范也称为_____, 主要有_____和_____两种方法。

解答: 系统加固、关闭闲置及危险端口、屏蔽出现扫描症状的端口

(3) 密码攻击一般有_____、_____和_____三种方法。其中_____有蛮力攻击和字典攻击两种方式。

解答: 网络监听非法得到用户密码、密码破解、放置特洛伊木马程序、密码破解

(4) 网络安全防范技术也称为_____, 主要包括访问控制、_____, _____、_____, 补丁安全、_____, 数据安全等。

解答: 加固技术、安全漏洞扫描、入侵检测、攻击渗透性测试、关闭不必要的端口与服务等

(5) 入侵检测系统模型由_____, _____、_____, _____以及_____五个主要部分组成。

解答: 信息收集器、分析器、响应、数据库、目录服务器

3.简答题

(1) 常用的黑客攻击技术有哪些? 对每一种攻击技术的防范对策是什么?

1) 端口扫描攻防

1) 端口扫描作用

网络端口为一组16位号码, 其范围为0~65535, 服务器在预设得端口等待客户端的连接。如WWW服务使用TCP的80号端口、FTP端口21、Telnet端口23。一般各种网络服务和管理都是通

过端口进行的，同时也为黑客提供了一个隐蔽的入侵通道。对目标计算机进行端口扫描能得到许多有用的信息。通过端口扫描，可以得到许多需要的信息，从而发现系统的安全漏洞防患于未然。端口扫描往往成为黑客发现获得主机信息的一种最佳途径。

2)端口扫描的防范对策

端口扫描的防范也称为系统“加固”，主要有两种方法。

- (1) 关闭闲置及危险端口
- (2) 屏蔽出现扫描症状的端口

2)网络监听攻防

网络嗅探就是使网络接口接收不属于本主机的数据。通常账户和密码等信息都以明文的形式在以太网上传输，一旦被黑客在杂错节点上嗅探到，用户就可能会遭到损害。

对于网络嗅探攻击，可以采取以下一些措施进行防范。

- (1) 网络分段
- (2) 加密
- (3) 一次性密码技术

5) 缓冲区溢出攻防

- (1) 编写正确的代码
- (2) 非执行的缓冲区
- (3) 数组边界检查
- (4) 程序指针完整性检查

6) 拒绝服务攻防

到目前为止，进行 DDoS 攻击的防御还是比较困难的。首先，这种攻击的特点是它利用了 TCP/IP 协议的漏洞。

检测 DDoS 攻击的主要方法有以下几种：

- (1)根据异常情况分析
- (2)使用 DDoS 检测工具

对 DDoS 攻击的主要防范策略包括：

- (1)尽早发现系统存在的攻击漏洞，及时安装系统补丁程序。
- (2)在网络管理方面，要经常检查系统的物理环境，禁止那些不必要的网络服务。
- (3)利用网络安全设备如防火墙等来加固网络的安全性。
- (4)比较好的防御措施就是和你的网络服务提供商协调工作，让他们帮助你实现路由的访问控制和对带宽总量的限制。
- (5)当发现自己正在遭受 DDoS 攻击时，应当启动应付策略，尽快追踪攻击包，并及时联系 ISP 和有关应急组织，分析受影响的系统，确定涉及的其他节点，从而阻挡已知攻击节点的流量。
- (6)对于潜在的 DDoS 攻击，应当及时清除，以免留下后患。

(2) 阐明特洛伊木马攻击的步骤及原理？

- 1) 使用木马工具进行网络入侵，基本过程可以分为 6 个步骤。
 - (1) 配置木马
 - (2) 传播木马
 - (3) 运行木马
 - (4) 泄露信息。收集一些服务端的软硬件信息，并通过 E-mail 或 ICQ 等告知控制端用户。
 - (5) 建立连接。服务端安装木马程序，且控制端及服务端都要在线。控制端可以通过木马端口与服务端建立连接。
 - (6) 远程控制。通过木马程序对服务端进行远程控制。

控制端口可以享有的控制权限：窃取密码、文件操作、修改注册表和系统操作。

2)特洛伊木马攻击原理

特洛伊木马是指隐藏在正常程序中一段具有特殊功能的恶意代码，是具备破坏和删除文件、发送密码、记录键盘和攻击 Dos 等特殊功能的后门程序。

一个完整的木马系统由硬件部分、软件部分和具体连接部分组成。

(6) 入侵检测系统的主要功能有哪些？其特点是什么？

入侵检测系统主要功能包括 6 个方面：

- (1) 监视、分析用户及系统活动；
- (2) 系统构造和弱点的审计；
- (3) 识别反映已知进攻的活动模式并向相关人员报警；
- (4) 异常行为模式的统计分析；
- (5) 评估重要系统和数据文件的完整性；
- (6) 操作系统的审计跟踪管理，并识别用户违反安全策略的行为。

入侵检测系统的特点：

入侵检测技术是动态安全技术的最核心技术之一，通过对入侵行为的过程与特征的研究，使安全系统对入侵事件和入侵过程能做出实时响应，是对防火墙技术的合理补充。

IDS 帮助系统防范网络攻击，扩展了系统管理员的安全管理功能，提高了信息安全基础结构的完整性。

入侵检测被认为是防火墙之后的第二道安全闸门，提供对内部攻击、外部攻击和误操作的实时保护。

入侵检测和安全防护有根本性的区别：安全防护和黑客的关系是“防护在明，黑客在暗”，入侵检测和黑客的关系则是“黑客在明，检测在暗”。安全防护主要修补系统和网络的缺陷，增加系统的安全性能，从而消除攻击和入侵的条件；入侵检测并不是根据网络和系统的缺陷，而是根据入侵事件的特征一般与系统缺陷有逻辑关系，对入侵事件的特征进行检测，所以入侵检测系统是黑客的克星。

(7) 简述网络安全防范攻击的基本措施有哪些？

1. 提高防范意识
2. 设置安全口令
3. 实施存取控制
4. 加密及认证
5. 定期分析系统日志
6. 完善服务器系统安全性能
7. 进行动态站点监控
8. 安全管理检测
9. 做好数据备份
10. 使用防火墙和防毒软件

(8) 简述端口扫描的原理。

最简单的端口扫描程序仅仅是检查目标主机在哪些端口可以建立 TCP 连接，如果可以建立连接，则说明主机在那个端口被监听。

对于非法入侵者而言，要想知道端口上具体提供的服务，必须用相应的协议来验证才能确定，因为一个服务进程总是为了完成某种具体的工作而设计的。

(9) 从网络安全角度分析为什么在实际应用中要开放尽量少的端口？

网络端口为一组16位号码，其范围为0~65535，服务器在预设得端口等待客户端的连接。如WWW服务使用TCP的80号端口、FTP端口21、Telnet端口23。一般各种网络服务和管理都是通过端口进行的，同时也为黑客提供了一个隐蔽的入侵通道。对目标计算机进行端口扫描能

得到许多有用的信息。通过端口扫描，可以得到许多需要的信息，往往成为黑客发现获得主机信息的一种最佳途径，所以从网络安全角度在实际应用中要开放尽量少的端口。

(10) 在实际应用中应怎样防范口令破译？

通常保持密码安全的要点：

- (1) 要将密码写下来，以免遗失；
- (2) 不要将密码保存在电脑文件中；
- (3) 不要选取显而易见的信息做密码；
- (4) 不要让他人知道；
- (5) 不要在不同系统中使用同一密码；
- (6) 在输入密码时应确认身边无人或其他人在 1 米线外看不到输入密码的地方；
- (7) 定期改变密码，至少 2—5 个月改变一次。

(11) 简述出现DDoS 时可能发生的现象。

被攻击主机上出现大量等待的 TCP 连接，网络中充斥着大量的无用数据包，源地址为假的，制造高流量无用数据，造成网络拥塞，使受害主机无法正常和外界通讯，利用受害主机提供的服务或传输协议上的缺陷，反复高速地发出特定的服务请求，使受害主机无法及时处理所有正常请求，严重时会造成系统死机。

(12) 简述电子邮件炸弹的原理及防范技术。

原理：是用伪造的 IP 地址和电子邮件地址向同一信箱发送数以千计、万计甚至无穷多次的内容相同的垃圾邮件，致使受害人邮箱被“炸”，严重者可能会给电子邮件服务器操作系统带来危险，甚至瘫痪。

防范技术：其防范方法与防范其他密码破解、拒收垃圾邮件和防范病毒方法类似。

第 5 章 身份认证与访问控制

1. 选择题

(1) 在常用的身份认证方式中，() 是采用软硬件相结合、一次一密的强双因子认证模式，具有安全性、移动性和使用的方便性。

- | | |
|------------|---------------|
| A. 智能卡认证 | B. 动态令牌认证 |
| C. USB Key | D. 用户名及密码方式认证 |

(2) 以下 () 属于生物识别中的次级生物识别技术。

- | | |
|---------|---------|
| A. 网膜识别 | B. DNA |
| C. 语音识别 | D. 指纹识别 |

(3) 数据签名的 () 功能是指签名可以证明是签字者而不是其他人在文件上签字。

- | | |
|-----------|-----------|
| A. 签名不可伪造 | B. 签名不可变更 |
| C. 签名不可抵赖 | D. 签名是可信的 |

(4) 在综合访问控制策略中，系统管理员权限、读/写权限、修改权限属于 ()。

- | | |
|-------------|------------|
| A. 网络的权限控制 | B. 属性安全控制 |
| C. 网络服务安全控制 | D. 目录级安全控制 |

(5) 以下 () 不属于 AAA 系统提供的服务类型。

- | | |
|-------|-------|
| A. 认证 | B. 鉴权 |
| C. 访问 | D. 审计 |

解答：(1) B (2) C (3) A (4) D (5) C

2. 填空题

(1) 身份认证是计算机网络系统的用户在进入系统或访问不同_____的系统资源时，系统确认该用户的身份是否_____、_____和_____的过程。

解答：保护级别、真实、合法、唯一

(2) 数字签名是指用户用自己的_____对原始数据进行_____得到_____，专门用于保证信息来源的_____、数据传输的_____和_____。

解答：私钥 加密、特殊数字串、真实性、完整性、防抵赖性

(3) 访问控制包括三个要素，即_____、_____和_____。访问控制的主要内容包括_____、_____和_____三个方面。

解答：主体 客体、控制策略、认证、控制策略实现、审计

(4) 访问控制模式有三种模式，即 _____、_____ 和 _____。

解答：自主访问控制 DAC、强制访问控制 MAC、基本角色的访问控制 RBAC

(5) 计算机网络安全审计是通过一定的_____，利用_____系统活动和用户活动的历史操作事件，按照顺序_____、_____和_____每个事件的环境及活动，是对和的要补充和完善。

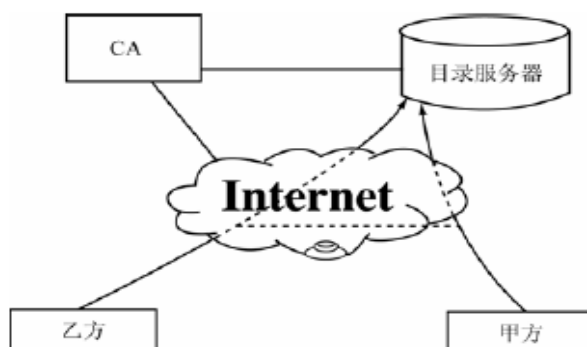
解答：安全策略、记录及分析、检查、审查、检验、防火墙技术、入侵检测技术

3. 简答题

(1) 简述数字签名技术的实现过程？

对一个电子文件进行数字签名并在网上传输，通常需要的**技术实现过程**包括：网上身份认证、进行签名和对签名的验证。

1. 身份认证的实现过程



PKI 提供的服务首先是认证，即身份识别与鉴别，就是确认实体即为自己所声明的实体。认证的前提是甲、乙双方都具有第三方 CA 所签发的证书。认证分单向认证和双向认证。

1) 单向认证，单向认证是甲、乙双方在网上通信时，甲只需要认证乙的身份。这时甲需要获取乙的证书，获取的方式有两种，一种是在通信时乙直接将证书传送给甲，另一种是甲向CA 的目录服务器查询索取。甲获得乙的证书后，首先用CA 的根证书公钥验证该证书的签名，验证通过说明该证书是第三方CA 签发的有效证书。然后检查证书的有效期及检查该证书是

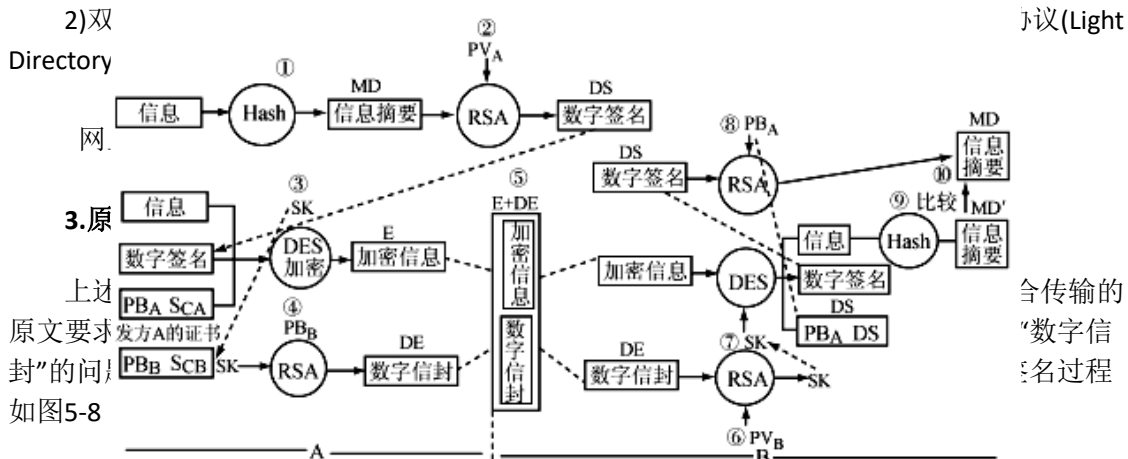


图5-8 原文加密的数字签名实现方法

这是一个典型的“数字信封”处理过程。其基本原理是将原文用对称密钥加密传输，而将对称密钥用收方公钥加密发送给对方。如同将对称密钥放在同一个数字信封，收方收到数字信封，用自己的私钥解密信封，取出对称密钥解密得原文。

原文加密的数字签名的过程：

- (1) 发方A 将原文信息进行哈希(Hash)运算，得到一哈希值，即数字摘要MD。
- (2) 发方A 用自己的私钥 PV_A ，采用非对称RSA 算法对数字摘要MD 进行加密，即得数字签名DS。
- (3) 发方A 用对称算法DES 的对称密钥SK 对原文信息、数字签名DS 及发方A 证书的公钥 PB_A 采用对称算法加密，得加密信息E。
- (4) 发方用收方B 的公钥 PB_B ，采用RSA 算法对对称密钥SK 加密，形成数字信封DE，就好像将对称密钥SK 装到了一个用收方公钥加密的信封里。
- (5) 发方A 将加密信息E 和数字信封DE 一起发送给收方B。
- (6) 收方B 接收到数字信封DE 后，首先用自己的私钥 PV_B 解密数字信封，取出对称密钥SK。
- (7) 收方B 用对称密钥SK 通过DES 算法解密加密信息E，还原出原文信息、数字签名DS 及发方A 证书的公钥 PB_A 。
- (8) 收方B 验证数字签名，先用发方A 的公钥解密数字签名得数字摘要MD。
- (9) 收方B 同时将原文信息用同样的哈希运算，求得一个新的数字摘要MD'。
- (10) 将两个数字摘要MD 和MD' 进行比较，验证原文是否被修改，如果二者相等，说明数据没有被篡改，是保密传输的，签名是真实的，否则拒绝该签名。这样就做到了敏感信息在数字签名的传输中不被篡改，其他没经认证和授权的人看不见或读不懂原数据，起到了在数字签名传输中对敏感数据的保密作用。以上就是现行电子签名中普遍被使用而又具有可操作性的、安全的、数字签名的技术实现原理和全部过程。

(3) 简述安全审计的目的和类型？

目的和意义在于：

- (1) 对潜在的攻击者起到重大震慑和警告的作用；
- (2) 测试系统的控制是否恰当，以便于进行调整，保证与既定安全策略和操作能够协调一致。
- (3) 对于已经发生的系统破坏行为，作出损害评估并提供有效的灾难恢复依据和追究责任的证据；
- (4) 对系统控制、安全策略与规程中特定的改变作出评价和反馈，便于修订决策和部署。
- (5) 为系统管理员提供有价值的系统使用日志，帮助系统管理员及时发现系统入侵行为或潜在的系统漏洞。

安全审计有三种类型：

- (1) 系统级审计
- (2) 应用级审计
- (3) 用户级审计

2. Windows NT 的访问控制过程

(1) 创建账号。当一个账号被创建时，Windows NT 系统为它分配一个安全标识（SID）。安全标识和账号唯一对应，在账号创建时创建，账号删除时删除，而且永不再用。安全标识与对应的用户和组的账号信息一起存储在 SAM 数据库里。

(2) 登录过程（LP）控制。每次用户登录时，用户应输入用户名、口令和用户希望登录的服务器/域等信息，登录主机把这些信息传送给系统的安全账号管理器，安全账号管理器将这些信息与 SAM 数据库中的信息进行比较，如果匹配，服务器发给客户机或工作站允许访问的信息，记录用户账号的特权、主目录位置、工作站参数等信息，并返回用户的安全标识和用户所在组的安全标识。工作站为用户生成一个进程。

(3) 创建访问令牌。当用户登录成功后，本地安全授权机构（LSA）为用户创建一个访问令牌，包括用户名、所在组、安全标识等信息。以后用户每新建一个进程，都将访问并复制令牌作为该进程的访问令牌。

(4) 访问对象控制。当用户或者用户生成的进程要访问某个对象时，安全引用监视器（SRM）将用户/进程的访问令牌中的安全标识（SID）与对象安全描述符（是 NT 为共享资源创建的一组安全属性，包括所有者安全标识、组安全标识、自主访问控制表、系统访问控制表和访问控制项）中的自主访问控制表进行比较，从而决定用户是否有权访问该对象。在这个过程中应该注意：安全标识（SID）对应账号的整个有效期，而访问令牌只对应某一次账号登录。

第 6 章 密码与加密技术

1. 选择题

- (1) () 密码体制，不但具有保密功能，并且具有鉴别的功能。
 - A. 对称
 - B. 私钥
 - C. 非对称
 - D. 混合加密体制
- (2) 网络加密方式的 () 是把网络上传输的数据报文的每一位进行加密，而且把路由信

息、校验和等控制信息全部加密。

- A. 链路加密
- B. 节点对节点加密
- C. 端对端加密
- D. 混合加密

(3) 恺撒密码是()方法, 被称为循环移位密码, 优点是密钥简单易记, 缺点是安全性较差。

- A. 代码加密
- B. 替换加密
- C. 变位加密
- D. 一次性加密

(4) 在加密服务中, () 是用于保障数据的真实性和完整性的, 目前主要有两种生成 MAC 的方式。

- A. 加密和解密
- B. 数字签名
- C. 密钥安置
- D. 消息认证码

(5) 根据信息隐藏的技术要求和目的, 下列() 不属于数字水印需要达到的基本特征。

- A. 隐藏性
- B. 安全性
- C. 完整性
- D. 强壮性

解答: (1) C (2) A (3) B (4) D (5) C

2. 填空题

(1) 在加密系统中, 原有的信息称为_____, 由_____变为_____的过程称为加密, 由_____还原成_____的过程称为解密。

解答: 明文、明文、密文、密文、明文

(2) _____是保护大型传输网络系统上各种信息的惟一实现手段, 是保障信息安全的_____。

解答: 密码技术、核心技术

(3) 对称密码体制加密解密使用_____的密钥; 非对称密码体制的加密解密使用_____的密钥, 而且加密密钥和解密密钥要求_____互相推算。

解答: 相同、不相同、无法

(4) 数据加密标准 DES 是_____加密技术, 专为_____编码数据设计的, 典型的按方式工作的_____密码算法。

解答: 代码加密、替换加密、变位加密、一次性加密

(5) 常用的加密方法有_____, _____, _____, _____四种。

解答：对称、二进制、分组、单钥

3.简答题

(3) 简述密码的破译方法和防止密码被破译的措施？

密码破译方法

1. 密钥的穷尽搜索

破译密文最简单的方法，就是尝试所有可能的密钥组合。如果破译者有识别正确解密结果的能力，虽然大多数的密钥组合破解尝试都可能失败，但最终有可能被破译者得到密钥和原文，这个过程称为**密钥的穷尽搜索**。

密钥的穷尽搜索，一般可用简单的工具软件或机械装置，如同组合密码攻击一样，搜索效率很低，甚至达到的程度很小。

如果加密系统密钥生成的概率分布不均匀，比如有些密钥组合根本不会出现，而另一些组合则经常出现，那么密钥的有效长度则减小了很多。破译者利用这种规律就可能大大加快搜索的速度。另外，利用多台或更先进的计算机进行分布式搜索，其威胁也是很大的。

2. 密码分析

密码分析就是在不知道密钥的情况下，利用数学方法破译密文或找到秘密密钥。

(1) 已知明文的破译方法：密码分析员可以通过一段明文和密文的对应关系，经过分析发现加密的密钥。所以，过时或常用加密的明文、密文和密钥，仍然具有被利用的危险性。

(2) 选定明文的破译方法：密码分析员可以设法让对手加密一段选定的明文，并获得加密后的结果，经过分析也可以确定加密的密钥。

(4) 如何进行简单的变位加密？已知明文是“来宾已出现住在人民路”， 密钥是：**4168257390**，则加密后，密文是什么？

简单的变位加密：首先选择一个用数字表示的密钥，写成一行，然后把明文逐行写在数字下。按密钥中数字指示的顺序，逐列将原文抄写下来，即为加密后的密文。

密钥：	4	1	6	8	2	5	7	3	9	0
明文：	来	宾	已	出	现	住	在	人	民	路
	0	1	2	3	4	5	6	7	8	9
密文：	路	宾	现	人	来	住	已	在	出	民

(5) 已知明文是“One World One Dream”，用 5 列变位加密后，密文是什么？

O	n	e	W	o
r	l	d	O	n
e	D	r	e	a
m				

则密文是：OremnlDedrWOeona

(6) 已知明文是“One World One Dream”，按行排在矩阵中，置换 $f = \begin{bmatrix} 1234 \\ 2413 \end{bmatrix}$ ，用矩阵变位加密方法后，密文是什么？

矩阵变位密码是把明文中的字母按给定的顺序排列在一个矩阵中，然后用另一种顺序选出矩阵的字母来产生密文。

按照置换 f 中第 1 行的顺序将明文安排在一矩阵中：

O	n	e	W
o	r	l	d

O n e D
r e a m

按照置换 f 中第 2 行的顺序 2413 将上述矩阵中的各行重新排列:

n W O e
r d o l
n D O e
e m r a

则密文是: nWOerdolnDOeemra

(7) 如何进行替换加密? 假设将字母 a, b, c, ..., x, y, z 的自然顺序保持不变, 但使之与 F, G, H, ..., A, B, C, D, E 分别对应, 此时密钥为 5 且大写, 按此方法若明文为 student, 则对应的密文是什么?

替换加密是指用一组密文字母来代替一组明文字母以隐藏明文, 同时保持明文字母的顺序不变的替换方式。一种最古老的替换密码是恺撒密码, 又被称为循环移位密码。

将字母 a, b, c, ..., x, y, z 的自然顺序保持不变, 但使之与 F, G, H, ..., A, B, C, D, E 分别对应, 此时密钥为 5 且大写。

若明文为 student, 则对应的密文为 XYZ IJSY。

第 7 章 数据库系统安全技术

1. 选择题

(1) 一个网络信息系统最重要的资源是_____。

- A. 计算机硬件
- B. 网络设备
- C. 数据库
- D. 数据库管理系统

(2) 不应拒绝授权用户对数据库的正常操作, 同时保证系统的运行效率并提供用户友好的人机交互指的是数据库系统的_____。

- A. 保密性
- B. 可用性
- C. 完整性
- D. 并发性

(3) 数据库安全可分为两类: 系统安全性和_____。

- A. 数据安全性
- B. 应用安全性
- C. 网络安全性
- D. 数据库安全性

(4) 下面哪一项不属于 Oracle 数据库的存取控制: _____。

- A. 用户鉴别
- B. 用户的表空间设置和定额
- C. 用户资源限制和环境文件
- D. 特权

(5) _____是防止合法用户使用数据库时向数据库中加入不符合语义的数据。

解答：数据库的存取控制、 特权和角色 、 审计

(7) _____是数据库保护的两个不同的方面。

解答：数据库的完整性和安全性

(8) 计算机系统中的数据备份通常是指将存储在_____等存储介质上，在计算机以外的地方另行保管。

解答：计算机系统中的数据复制到磁带, 磁盘, 光盘

(9) _____是指数据库管理员定期地将整个数据库复制到磁带或另一个磁盘上保存起来的过程。这些备用的数据文本称为_____。

解答： 转储、 后备副本或后援副本

(10) 数据备份的类型按备份的数据量来分，有_____。

解答：完全备份、增量备份、差分备份和按需备份

(11) 数据恢复操作通常有三种类型：_____。

解答：全盘恢复、个别文件恢复和重定向恢复

(12) 异构环境的数据库安全策略有 _____、 _____、
和 _____。

解答：系统安全性策略、用户安全性策略、 数据库管理者安全性策略、应用程序开发者安全性策略

3. 简答题

(5) 什么叫数据的备份和恢复？

数据备份

- 数据备份 (Data Backup) 就是指为防止系统出现操作失误或系统故障导致数据丢失，而将全系统或部分数据集合从应用主机的硬盘或阵列中复制到其它存储介质上的过程。计算机系统中的数据备份，通常是指将存储在计算机系统的数据复制到磁带、磁盘、光盘等存储介质上，在计算机以外的地方另行保管。
- 数据备份也就是把数据库数据复制到转储设备的过程。其中，转储设备是指用于放置数据库拷贝的磁带或磁盘。为实现数据恢复，必须建立冗余数据，而常用的技术就是数据转储和登记日志文件。

数据恢复 (Data Restore)

是指将备份到存储介质上的数据再恢复到计算机系统中，它与数据备份是一个相反的过程，数据恢复包括整个数据库系统的恢复。数据恢复措施在整个数据安全保护中占有相当重要的地位，因为它直接关系到系统在经历灾难后能否迅速恢复正常运行。

第 8 章 病毒及恶意软件的防护

1. 选择题

(1) 在计算机病毒发展过程中, () 给计算机病毒带来了第一次流行高峰, 同时病毒具有了自我保护的功能。

- A. 多态性病毒阶段
- B. 网络病毒阶段
- C. 混合型病毒阶段
- D. 主动攻击型病毒

(2) 以病毒攻击的不同操作系统分类中, () 已经取代 D.OS 系统, 成为病毒攻击的主要对象。

- A. UNIX 系统
- B. OS/2 系统
- C. WinDows 系统
- D. NetWAre 系统

(3) () 是一种更具破坏力的恶意代码, 能够感染多种计算机系统, 其传播之快、影响范围之广、破坏力之强都是空前的。

- A. 特洛伊木马
- B. CIH 病毒
- C. CoDeReDII 双型病毒
- D. 蠕虫病毒

(4) 按照计算机病毒的链接方式不同分类, () 是将其自身包围在合法的主程序的四周, 对耕牛来的程序不做修改。

- A. 源码型病毒
- B. 外壳型病毒
- C. 嵌入型病毒
- D. 操作系统型病毒

(5) () 属于蠕虫病毒, 由 Delphi 工具编写, 能够终止大量的反病毒软件和防火墙软件进程。

- A. 熊猫烧香
- B. 机器狗病毒
- C. AV 杀手
- D. 代理木马

解答: (1) C (2) C (3) D (4) B (5) A

2. 填空题

(1) 计算机病毒是在_____中插入的破坏计算机功能的数据, 影响计算机使用并且能够_____的一组计算机指令或者_____。

(1) 计算机程序、自我复制、程序代码

(2) 病毒基本采用_____法来进行命名。病毒前缀表示_____, 病毒名表示_____, 病毒后缀表示_____。

(2) 前后缀、病毒的种类、病毒的名称、病毒的变种特征

(3) 计算机病毒按传播方式分为_____、_____、_____。

(3) 引导型病毒、文件型病毒和混合型病毒

(4) 计算机病毒的组织结构包括_____、_____和_____。

(4) 引导模块、传播模块、表现模块

(5) _____、_____、_____、_____是计算机病毒的基本特征。

_____使病毒得以传播，_____体现病毒的杀伤能力，_____是病毒的攻击性的潜伏性之间的调整杠杆。

(5) 感染、潜伏、可触发、破坏、感染、破坏性、可触发性

3.简答题

(1) 简述计算机病毒的特点有哪些？

根据对计算机病毒的产生、传播和破坏行为的分析，可以将计算机病毒概括为以下 6 个主要特点。

1. 自我复制能力
2. 取得系统控制权
3. 隐蔽性
4. 破坏性
5. 潜伏性
6. 不可预见性

(3) 简述计算机病毒发展的过程？

计算机病毒伴随计算机、网络信息技术的快速发展而日趋复杂多变，其破坏性和传播能力也不断增强。计算机病毒发展主要经历了五个重要的阶段。

- (1) 原始病毒阶段（第一阶段）
- (2) 混合型病毒阶段（第二阶段）
- (3) 多态性病毒阶段（第三阶段）
- (4) 网络病毒阶段（第四阶段）
- (5) 主动攻击型病毒阶段（第五阶段）

(8) 简述计算机的新防病毒技术？

病毒清除的新技术和最新的发展方向主要体现在以下四个方面：

- (1) 实时监测技术
- (2) 自动解压缩技术
- (3) 跨平台反病毒技术
- (4) 云端杀毒技术

第 9 章 防火墙应用技术

1. 选择题

- (1) 拒绝服务攻击的一个基本思想是 ()
- A. 不断发送垃圾邮件工作站
B. 迫使服务器的缓冲区满
C. 工作站和服务端停止工作
D. 服务器停止工作
- (2) TCP 采用三次握手形式建立连接, 在 () 时候开始发送数据。
- A. 第一步 B. 第二步 C. 第三步之后 D. 第三步
- (3) 驻留在多个网络设备上的程序在短时间内产生大量的请求信息冲击某 web 服务器, 导致该服务器不堪重负, 无法正常相应其他合法用户的请求, 这属于 ()
- A. 上网冲浪 B 中间人攻击 C. DDoS 攻击 D. MAC 攻击
- (4) 关于防火墙, 以下 () 说法是错误的。
- A. 防火墙能隐藏内部 IP 地址
B. 防火墙能控制进出内网的信息流向和信息包
C. 防火墙能提供 VPN 功能
D. 防火墙能阻止来自内部的威胁
- (5) 以下说法正确的是 ()
- A. 防火墙能够抵御一切网络攻击
B. 防火墙是一种主动安全策略执行设备
C. 防火墙本身不需要提供防护
D. 防火墙如果配置不当, 会导致更大的安全风险
- 解答: B C C D D

2. 填空题

- (1) 防火墙隔离了内部、外部网络, 是内、外部网络通信的_____途径, 能够根据制定的访问规则对流经它的信息进行监控和审查, 从而保护内部网络不受外界的非访问和攻击。
- 唯一
- (2) 防火墙是一种_____设备, 即对于新的未知攻击或者策略配置有误, 防火墙就无能为力了。
- 被动安全策略执行
- (3) 从防火墙的软、硬件形式来分的话, 防火墙可以分为_____防火墙和硬件防火墙以及_____防火墙。
- 软件、芯片级
- (4) 包过滤型防火墙工作在 OSI 网络参考模型的_____和_____。
- 网络层、传输层
- (5) 第一代应用网关型防火墙的核心技术是_____。
- 代理服务器技术
- (6) 单一主机防火墙独立于其它网络设备, 它位于_____。

网络边界

- (7) 组织的雇员，可以是要到外围区域或 Internet 的内部用户、外部用户（如分支机构工作人员）、远程用户或在家中办公的用户等，被称为内部防火墙的_____。

完全信任用户

- (8) _____是位于外围网络中的服务器，向内部和外部用户提供服务。

堡垒主机

- (9) _____利用 TCP 协议的设计上的缺陷，通过特定方式发送大量的 TCP 请求从而导致受攻击方 CPU 超负荷或内存不足的一种攻击方式。

SYN Flood

- (10) 针对 SYN Flood 攻击，防火墙通常有三种防护方式：_____、被动式 SYN 网关和_____。

SYN 网关、SYN 中继

3. 简答题

(1) 防火墙是什么？

防火墙是一种位于两个（或多个）网络之间，通过执行访问控制策略来保护网络安全设备。它隔离了内部、外部网络，是内、外部网络通信的唯一途径，能够根据制定的访问规则对流经它的信息进行监控和审查，从而保护内部网络不受外界的非访问和攻击。

(2) 简述防火墙的分类及主要技术

1 以防火墙的软硬件形式分类

可以分为软件防火墙和硬件防火墙以及芯片级防火墙。

- (1) 软件防火墙需要客户预先安装好的计算机操作系统的支持，俗称个“人防火墙”。
- (2) 硬件防火墙一般至少应具备三个端口，分别接内网，外网和 DMZ 区。
- (3) 芯片级防火墙基于专门的硬件平台，没有操作系统。专有的 ASIC 芯片促使它们比其他种类的防火墙速度更快，处理能力更强，性能更高。

3 以防火墙体系结构分类

主要有：单一主机防火墙、路由器集成式防火墙和分布式防火墙三种。

- (1) 单一主机防火墙是最为传统的防火墙，独立于其它网络设备，它位于网络边界。
- (2) 路由器集成式防火墙是将防火墙功能集成在中、高档路由器中，大大降低了网络设备购买成本。
- (3) 分布式防火墙不是只是位于网络边界，而是渗透于网络的每一台主机，对整个内部网络的主机实施保护。

(3) 防火墙的基本结构是怎样的？如何起到“防火墙”的作用？

主要有：单一主机防火墙、路由器集成式防火墙和分布式防火墙三种。

- (1) 单一主机防火墙是最为传统的防火墙，独立于其它网络设备，它位于网络边界。
- (2) 路由器集成式防火墙是将防火墙功能集成在中、高档路由器中，大大降低了网络设备购买成本。

(3) 分布式防火墙不是只是位于网络边界，而是渗透于网络的每一台主机，对整个内部网络的主机实施保护。

第10章 操作系统与站点安全

一、选择题

- (1) 应对操作系统安全漏洞的基本方法不包括下面的 ()
- A. 对默认安装进行必要的调整
 - B. 给所有用户设置严格的口令
 - C. 及时安装最新的安全补丁
 - D. 更换到另一种操作系统
- (2) 网络操作系统应当提供的安全保障不包括下面的 ()
- A. 验证(Authentication)
 - B. 授权(Authorization)
 - C. 数据保密性(Data Confidentiality)
 - D. 数据一致性(Data Integrity)
 - E. 数据的不可否认性(Data Nonrepudiation)
- (3) 严格的口令策略不应当包含的要素是 ()
- A. 满足一定的长度，比如 8 位以上
 - B. 同时包含数字，字母和特殊字符
 - C. 系统强制要求定期更改口令
 - D. 用户可以设置空口令
- (4) 恶意软件保护包括两部分内容：()
- A. 病毒防护和 windows defender
 - B. 病毒防护和实时保护
 - C. WINDOWS DEFENDER 和实时保护
 - D. Windows Defender 和扫描选项
- (5) 范围广或异常的恶意程序，与病毒或蠕虫类似，会对用户的隐私和计算机安全造成负面影响，并损害计算机，这种警告登记属于：()
- A. 严重
 - B. 高
 - C. 中
 - D. 低
- (6) 如果软件试图更改重要的 Windows 设置，也会发出警报。由于软件已在计算机上运行，因此可以选择下列操作之一：()
- A. 隔离
 - B. 删除
 - C. 始终允许
 - D. 许可
- (7) 可以选择想要 Windows Defender 监视的软件和设置，但建议选中所有名为“代理”的实时保护选项，后面叙述属于什么类别实时代理保护：监视在启动计算机时允许其自动运行的程序的列表。间谍软件和其他可能不需要的软件可设置为在 Windows 启动时自动运行。这样，它便能够在用户未指示的情况下运行并搜集信息。还会使计算机启动或运行缓慢。()
- A. 自动启动
 - B. 系统配置 (设置)
 - C. Internet Explorer 加载项
 - D. Internet Explorer 配置 (设置)
- (8) 允许用户使用计算机的大多数功能，但是如果要进行的更改会影响计算机的其他用户或安全，则需要管理员的许可，属于什么帐户？()

- A. 标准
- B. 管理员
- C. 来宾
- D. 贵宾

解答：D、E、D、A 、A、A、A、A

2. 填空题

(1) 操作系统安全防护研究通常包括以下几方面内容：_____、
_____、_____。

(1) 操作系统安全防护研究通常包括以下几方面内容：操作系统本身提供的安全功能和安全服务、采取什么样的配置措施、提供的网络服务得到安全配置

(2) 安全策略描述的是_____。

(2) 安全策略描述的是人们如何存取文件或其他信息

(3) “用户帐户保护”可提高用户的工作效率，并允许用户_____。

(3) “用户帐户保护”可提高用户的工作效率，并允许用户更改公共设置而不要求具有管理权限

(4) _____是迄今为止开发的最为安全的 Windows 版本。在_____安全提升的基础上新增并改进了许多安全功能。

(4) Windows Vista 是迄今为止开发的最为安全的 Windows 版本。在 Windows XP SP2 安全提升的基础上新增并改进了许多安全功能。

(5) UNIX 系统中，安全性方法的核心是_____和_____。要成功注册进入 UNIX 系统，必须打入有效的用户标识，一般还必须输入正确的口令。口令是以加密形式存放在_____文件中

(5) UNIX 系统中，安全性方法的核心是每个用户的注册标识(loginid)和口令(password)。要成功注册进入 UNIX 系统，必须打入有效的用户标识，一般还必须输入正确的口令。口令是以加密形式存放在/etc/passwd 文件中

(6) 综合分析 Linux 主机的使用和管理方法，可以把它的安全性问题归纳为如下几个方面：(1) _____ (2) _____ (3) _____ (4) _____ (5) _____

(6) 综合分析 Linux 主机的使用和管理方法，可以把它的安全性问题归纳为如下几个方面：(1) 系统用户管理的安全性 (2) 特权文件 (3) 系统资源的访问控制 (4) 主机间的信任关系 (5) 网络服务

(7) LINUX 操作系统内核已知漏洞 (1) _____ (2) _____ (3) _____

(7) LINUX 操作系统内核已知漏洞 (1) 权限提升类漏洞 (2) 拒绝服务类漏洞 (3) IP 地址欺骗类漏洞

(8) Linux 系统的账号的安全策略：口令一般不小于_____个符号，一般应同时包含大小写、字母和数字以及特殊符号，不要使用常用单词、英文简写、个人信息等，不要在不同

系统上，特别是不同级别的用户上使用_____。

(8) Linux 系统的账号的安全策略：口令一般不小于 6 个符号，一般应同时包含大小写、字母和数字以及特殊符号，不要使用常用单词、英文简写、个人信息等，不要在不同系统上，特别是不同级别的用户上使用同一口令。

(9) Internet 上存在的主要安全隐患主要体现在下列几方面：____、____、____、____。

(9) Internet 上存在的主要安全隐患主要体现在下列几方面：开放的、无控制机构的网络、基于 TCP/IP 通信协议、使用 Unix 操作系统来支持、信息的来源和去向是否真实，内容是否被改动，以及是否泄露、电子邮件存在着被拆看、误投和伪造的可能性、计算机病毒通过 Internet 的传播给上网用户带来极大的危害

(10) Web 欺骗是一种_____，攻击者在其中创造了整个 Web 世界的一个令人信服但是完全错误的拷贝。

(10) Web 欺骗是一种电子信息欺骗，攻击者在其中创造了整个 Web 世界的一个令人信服但是完全错误的拷贝。

(11) Web 服务是基于_____的服务

(11) Web 服务是基于超文本传输协议(即 HTTP 协议)的服务

(12) 配置 Web 服务器一般包括以下几个方面的内容：____；____；____。

(12) 配置 Web 服务器一般包括以下几个方面的内容：认真选择 Web 服务器设备和相关软件；配置 Web 服务器，使用它的访问和安全特性；组织和 Web 服务器相关的内容。

(13) 恢复也可以分为两个方面：_____和_____。系统恢复指的是_____。

(13) 恢复也可以分为两个方面：系统恢复和信息恢复。系统恢复指的是修补该事件所利用的系统缺陷，不让黑客再次利用这样的缺陷入侵。

(14) 一般系统恢复包括_____、_____和_____等。系统恢复的另一个重要工作是_____。信息恢复指的是_____。

(14) 一般系统恢复包括系统升级、软件升级和打补丁等。系统恢复的另一个重要工作是除去后门。信息恢复指的是恢复丢失的数据。

3. 简答题

(11) 什么是 Web 欺骗？

Web 欺骗是一种电子信息欺骗，攻击者在其中创造了整个 Web 世界的一个令人信服但是完全错误的拷贝。错误的 Web 看起来十分逼真，它拥有相同的网页和链接。然而，攻击者控制着错误的 Web 站点，这样受攻击者浏览器和 Web 之间的所有网络信息完全被攻击者所截获，其工作原理就好像是一个过滤器。

(13) 简述 Web 服务器的安全策略和安全机制

服务器的安全策略是由个人或组织针对安全而制定的一整套规则和决策。每个 Web 站点都应有一个安全策略，这些安全策略因需求的不同而各不相同。对 Web 服务提供者来说，安全策略的一个重要的组成是哪些人可以访问哪些 Web 文档，同时还定义获权访问 Web 文档的人和使用这些访问的人的有关权力和责任。采取何种安全措施，取决于制定的安全策略。必须根据需求和目标来设置安全措施，估计和分析安全风险。制定 Web 站点的安全策略的基本原则是不要为细节所困扰。

安全机制是实现安全策略的技术或手段。必须根据需求和目标来设置安全系统，估计和分析可能的风险。

(14) 如何配置 Web 服务器

配置 Web 服务器一般包括以下几个方面的内容：认真选择 Web 服务器设备和相关软件；配置 Web 服务器，使用它的访问和安全特性；组织和 Web 服务器相关的内容。配置主要包括以下步骤：

1) 联机检查。检查源程序，查看连接 URL 和相应的内容是否图文一致，查看 URL 所提供的内容是否和网页的描述一致。检查驱动器和共享的权限，系统设为只读状态。

2) 检查 HTTP 服务器使用的 Applet 脚本，尤其是与其客户交互作用的 CGI 脚本，防止非法用户恶意使用 CGI 程序，执行内部指令，对 Web 服务器造成破坏。

3) 充分考虑最糟糕的情况后，配置自己的系统，即使黑客完全控制了系统，他还要面对一堵高墙。

4) 将敏感文件放在基本系统中，再设二级系统，使所有的敏感数据不向 Internet 开放。

第11章 电子商务安全

1. 选择题

(1) 电子商务对安全的基本要求不包括 ()

- A. 存储信息的安全性和不可抵赖性
- B. 信息的保密性和信息的完整性
- C. 交易者身份的真实性和授权的合法性
- D. 信息的安全性和授权的完整性

(2) 在 Internet 上的电子商务交易过程中，最核心和最关键的问题是 ()

- A. 信息的准确性
- B. 交易的不可抵赖性
- C. 交易的安全性
- D. 系统的可靠性

(3) 电子商务以电子形式取代了纸张，在它的安全要素中 () 是进行电子商务的前提条件。

- A. 交易数据的完整性
- B. 交易数据的有效性
- C. 交易的不可否认性
- D. 商务系统的可靠性

(4) 应用在电子商务过程中的各类安全协议，() 提供了加密、认证服务，并可以实现报文的完整性，以完成需要的安全交易操作。

- A. 安全超文本传输协议 (S-HTTP) B. 安全交易技术协议 (STT)
C. 安全套接层协议 (SSL) D. 安全电子交易协议 (SET)
- (5) () 将 SET 和现有的银行卡支付的网络系统作为接口, 实现授权功能。
- A. 支付网关 B. 网上商家
C. 电子货币银行 D. 认证中心 CA

解答:

- (1) D (2) C (3) B (4) C (5) A

2. 填空题

- (1) 电子商务按应用服务的领域范围分类, 分为 _____ 和 _____ 两种模式。

- (1) 企业对终端客户 (或 B2C) 企业对企业 (或 B2B)

- (2) 电子商务的安全性主要包括五个方面, 它们是 _____、 _____、 _____、 _____、 _____。

(2) 系统的可靠性、交易的真实性、数据的安全性、数据的完整性、交易的不可抵赖性

- (3) 一个完整的电子商务安全体系由 _____、 _____、 _____、 _____ 四部分组成。

- (3) 网络基础结构层、PKI 体系结构层 安全协议层 应用系统层

- (4) 安全套接层协议是一种 _____ 技术, 主要用于实现 _____ 和 _____ 之间的安全通信。 _____ 是目前网上购物网站中经常使用的一种安全协议。

- (4) 信用卡 付款协议书 对客户信用卡的认证 对商家身份的认证

3. 简答题

- (2) 在电子商务过程中, 商务安全存在哪些风险和隐患?

一般来说商务安全中普遍存在着以下几种安全风险和隐患:

- (1) 窃取信息
(2) 篡改信息
(3) 假冒
(4) 恶意破坏

- (5) SET 是如何保护在因特网上付款的交易安全?

SET 是一种用于保护在因特网上付款交易的开放式规范, 它包含交易双方身份的确认, 个人和金融信息私密性及传输数据完整性的保护, 其规格融合了由RSA 数据的双钥密码体制编成密码文件的技术, 以保护任何开放型网络上个人和金融信息的私密性。SET 提供了一

套既安全又方便的交易模式，并采用开放式的结构以期支持各种信用卡的交易。在每个交易环节中都加入电子商务的安全性认证过程。在SET 的交易环境中，比现实社会中多一个电子商务的安全性认证中心——电子商务的安全性CA 参与其中，在SET 交易中认证是关键。

(6) 基于 SET 协议的电子商务系统的业务过程有哪几个？

具体主要有 4 个业务认证过程：

- (1) 注册登记。
- (2) 申请数字证书。
- (3) 动态认证。
- (4) 商业机构处理。

(10) SSL 加密协议的用途是什么？

1. 安全套接层协议 SSL

安全套接层协议(Secure Sockets Layer，简称 SSL)为一种传输层技术，主要用于实现兼容浏览器和 Web 服务器之间的安全通信。

SSL 协议是目前网上购物网站中经常使用的一种安全协议。使用它在于确保信息在网际网络上流通的安全性，让浏览器和 Web 服务器能够安全地进行沟通。Microsoft 和 Netscape 的浏览器都支持 SSL，很多 Web 服务器也支持 SSL。

2. SSL 提供的服务

SSL 标准主要提供了 3 种服务：

- 1) 数据加密服务
- 2) 认证服务
- 3) 数据完整性服务

第 12 章 网络安全解决方案

1. 选择题

- (1) 在设计网络安全方案中，系统是基础、() 是核心、管理是保证。
 - A. 系统管理员
 - B. 安全策略
 - C. 人
 - D. 领导
- (2) 得到授权的实体在需要时可访问数据，即攻击者不能占用所有的资源而阻碍授权者的工作，以上是实现安全方案的 () 目标。
 - A. 可审查性
 - B. 可控性
 - C. 机密性
 - D. 可用性
- (3) 在设计编写网络方案时，() 是网络安全方案与其他项目的最大区别。
 - A. 网络方案的相对性
 - B. 网络方案的动态性
 - C. 网络方案的完整性
 - D. 网络方案的真实性
- (4) 在某部分系统出现问题时，不影响企业信息系统的正常运行，是网络方案设计中 () 需求。
 - A. 可控性和可管理性
 - B. 可持续发展
 - C. 系统的可用性
 - D. 安全性和合法性

(5) 在网络安全需求分析中, 安全系统必须具有 (), 以适应网络规模的变化。

- A. 可伸缩性
- B. 安全体系
- C. 易于管理
- D. 开放性

解答:

(1) C (2) D (3) B (4) C (5) A

2. 填空题

(1) 高质量的网络安全解决方案主要体现在_____、_____和_____三方面, 其中_____是基础、_____是核心、_____是保证。

(1) 安全技术 安全策略 安全管理 安全技术 安全策略 安全管理

(2) 网络系统的安全原则体现在 _____、_____、_____、_____和_____五个方面。

(2) 动态性 唯一性 整体性 专业性 严密性

(3) _____是识别与防止网络攻击行为、追查网络泄密行为的重要措施之一。

(3) 安全审计

(4) 在网络安全设计方案中, 只能做到 _____和_____, 不能做到_____。

(4) 避免风险 消除风险的根源 完全消灭风险

(5) 常用的安全产品主要有五种: _____、_____、_____、_____和_____。

(5) 防火墙 防病毒 身份认证 传输加密 入侵检测

解答:

(1) 安全技术 安全策略 安全管理 安全技术 安全策略 安全管理

(2) 动态性 唯一性 整体性 专业性 严密性

(3) 安全审计

(4) 避免风险 消除风险的根源 完全消灭风险

(5) 防火墙 防病毒 身份认证 传输加密 入侵检测

3. 简答题

(2) 网络安全的目标及设计原则是什么？

1. 安全方案的目标

应用网络安全技术设计网络安全方案的目标：

- (1) 各部门、各单位局域网的安全保护
 - (2) 与 Internet 相连的安全保护
 - (3) 关键信息的加密传输与存储
 - (4) 应用业务系统的安全
 - (5) 安全网的监控与审计
 - (6) 最终目标：机密性、完整性、可用性、可控性与可审查性
- 具体地主要包括以下 3 个方面：访问控制、数据加密、安全审计

2. 网络安全方案设计原则

- (1) 努力提高系统的安全性和保密性；
- (2) 保持网络原有的性能特点，对网络的协议和传输具有很好的透明性；
- (3) 易于操作、维护，并便于自动化管理，而不增加或少增加附加操作；
- (4) 尽量不影响原网络拓扑结构，同时便于系统及系统功能的扩展；
- (5) 安全保密系统具有较好的性能价格比，一次性投资，可以长期使用；
- (6) 安全与密码产品具有合法性，及经过国家有关管理部门的认可或认证；
- (7) 分步实施。对于网络安全综合解决方案，需要采取几个阶段进行分步实施、分段验收、确保总体质量。